

Section 1. Multi-Factor Authentication (MFA / 2FA) Requirements

- **Mandatory Enforcement:** Multi-factor authentication is mandatory for all Organization Administrator and Billing Manager roles across all subscription tiers.
- **Supported Authenticators:** Standard time-based one-time password (TOTP) applications including Google Authenticator, Microsoft Authenticator, 1Password, and FIDO2 WebAuthn hardware security keys (e.g. YubiKey).
- **SMS Deprecation:** SMS text-message 2FA is formally deprecated due to SIM-swapping vulnerabilities and cannot be configured for administrative access.
- **Emergency Recovery Codes:** Upon enabling MFA, users receive 10 single-use emergency backup recovery codes. These must be stored offline.

Section 2. Password Reset Protocols & Identity Verification

- **Reset Trigger:** Password resets must be initiated from the login portal using verified corporate domain email addresses.
- **Token Expiration:** Reset tokens are strictly valid for **15 minutes** from generation and expire immediately upon first usage.
- **Locked Accounts:** Accounts undergo temporary automated lockout for **30 minutes** following 5 consecutive failed authentication attempts.
- **Manual Verification:** If both password and 2FA recovery codes are lost, account recovery requires video identity verification with government-issued photo ID and notarized corporate email authorization.

Section 3. User Data Retention, Export & Deletion (GDPR/CCPA)

- **Data Export:** Account administrators can generate a comprehensive JSON/CSV archive containing all customer telemetry, tickets, and analytics logs from the Privacy Center at any time. Exports take 2 to 4 hours to compile and remain downloadable for 7 days.
- **Right to Erasure (Deletion Requests):** Data deletion requests processed under GDPR or CCPA are fulfilled within **30 calendar days**.
- **Cryptographic Shredding:** Backups containing customer data are permanently expunged through cryptographic key destruction within 90 days following account closure.

Section 4. Role-Based Access Control (RBAC) & Team Delegation

- **Predefined Roles:** The system enforces four discrete permission levels:
 - **Super Admin:** Full destructive access, billing control, and security policy enforcement.
 - **Billing Admin:** Invoicing, subscription changes, payment cards, without production data access.
 - **Member / Contributor:** Standard read/write access to analytics, dashboards, and API endpoints.
 - **Viewer (Read-Only):** Audit observation and dashboard viewing with zero modification rights.
- **Session Timeout:** Administrative sessions automatically expire and log out after **60 minutes** of inactivity.

Section 5. Security Incident Reporting & Audit Logs

- **Audit Logging:** Every user login, API key generation, permission modification, and data export is immutably recorded in the SIEM audit stream with source IP, timestamp, and user agent.
- **Incident Disclosure SLA:** In the event of a verified unauthorized data breach, customer security officers are notified within **72 hours** in compliance with Article 33 GDPR standards.
- **Reporting Vulnerabilities:** Security researchers may submit vulnerability reports directly to security@enterprise.com with PGP encryption.